MIDTERM STUDY GUIDE

Computer Security · Weeks 1–7

Condensed, comprehensive review for efficient midterm preparation

What is valuable?	What can harm it?	Why could it succeed?	How serious?	What do we do?

Scope note

This guide covers every lecture in the repo: weeks 1 to 7. Week 4 (identity, authentication and access control) and Week 7 (network defense, firewalls, segmentation, IDS/IPS, Wireshark, encryption boundaries, secure Wi-Fi and router hardening) are included in full depth.

Important exam note

The slides never state the midterm format, so this guide prepares for the three things every lecture practised: (1) **define a term** in plain English, (2) **classify a scenario** (which CIA goal, which malware type, which phishing label, which risk level), and (3) **explain a real case** using asset / threat / vulnerability / control. The course teaches protection, not attack: no question will ask you how to perform an attack.

Prepared from the week 1–6 slides, my notes and the assignments.

How to Use This Guide

This guide replaces re-reading seven slide decks. It keeps the lecture order, the lecturer's own terms and every real case, and drops repeated examples.

Study in three passes

Pass	What to do
1. Learn the chain	Asset → threat → vulnerability → exploit → control → risk. Every later week reuses these six words.
2. Review each week	Definitions, the comparison tables, and what each real case teaches.
3. Test yourself	Use the self-check section at the end. If you cannot answer in one or two sentences, go back to that week.

What "explain a case" means

- Name the **asset** that was harmed and which **CIA goal** it lost.
- Separate the **threat** (who or what caused harm) from the **vulnerability** (the weakness that let it work).
- Name one **control** and say whether it **prevents, detects or recovers**, and whether it lowers **likelihood** or **impact**.

> **Do not memorize dates only**
> A date with no lesson scores nothing. For every case know one sentence: *what happened* and *what it teaches*. The case table near the end has all of them.

The Course as One System

Asset	Threat	Vulnerability	Exploit	Control	Risk

Each week answers a different question:

Week	Main question	Core concepts
1	What does security protect?	Definition of security, CIA triad, five words, pause-check-report, permission, defense in depth
2	What matters, what can harm it, how serious is it?	Four asset types, threat / vulnerability / exploit / control, prevent-detect-recover, MFA, backup vs restore, risk matrix
3	How are people attacked?	Social engineering, pretext vs action, six levers, phishing family, warning signs, reporting routes
4	Who is asking, and is this request allowed?	Identification / authentication / authorization, account / session / permission, online vs offline guessing, salt and Argon2id, MFA factor types, roles and scope, horizontal vs vertical failure, least privilege
5	How is a device attacked?	Six malware categories, seven infection paths, endpoint controls, trusted-state recovery
6	Where does data travel, and where does security matter?	LAN/WAN, switch/AP/router, IP/port/protocol/DNS, HTTPS boundary, evil twin, firewall, segmentation
7	How is network traffic defended and Wi-Fi secured?	Firewalls (inbound vs outbound), rule structure (source, dest, service, allow/deny), network segmentation, IDS vs IPS, false positives vs false negatives, Wireshark packet capture (packet list, details, bytes), plain HTTP vs HTTPS, encryption boundaries (WPA vs TLS vs VPN), router two-password model, Wi-Fi security modes (WPA3 / WPA2 / WEP / Open), router hardening (firmware, remote admin, WPS)

Key distinction

Week 2 gives the **framework**. Week 3 applies it to **people**, week 4 to **accounts**, week 5 to **devices**, week 6 to **network structure and basic path**, week 7 to **network defense, monitoring and secure Wi-Fi**. The same answer pattern works everywhere: **location or asset → weakness → control**.

Week 1 - Introduction to Computer Security

Definition

Computer security is the set of ideas, practices and controls used to reduce **unauthorized access**, **unwanted change** and **harmful disruption**.

Protect access	Protect accuracy	Protect use

Those three map onto confidentiality, integrity and availability.

What we protect

Area	Examples
Information	Grades, messages, research, identity data, payment details
Devices + services	Phones, laptops, LMS, email, cloud storage, campus Wi-Fi
People + reputation	Time, trust, privacy, safety, the ability to study or work

The CIA triad

Goal	Key question	School example	Typical failure	Typical controls
Confidentiality	Who is allowed to see it?	Only the student and authorized staff see a grade	Reading someone's email, public sharing of a private file, shoulder-surfing	Screen lock, unique password, MFA, sharing permissions
Integrity	Is it correct, complete, trustworthy?	An assignment arrives exactly as submitted	Altered grade, old file uploaded, corrupted storage	Access control, validation, logs and version history, hashes, backups
Availability	Can authorized people use it when needed?	LMS works before a deadline	DoS traffic, ransomware, power or hardware failure, bad update	Backups, redundancy, maintenance, monitoring, recovery plans

Important

Integrity and availability can fail **by accident**, with no attacker: editing the wrong row, a software bug, a power failure. An accident is still a security problem because the data is no longer trustworthy or usable.

Which CIA goal? (practise this)

Situation	Goal
A student's grades are posted publicly	C
Someone changes a submitted assignment	I
The LMS is offline before a deadline	A
A shared file is corrupted and cannot open	I (and as a result A)

Balance

- More protection can add effort: MFA improves confidentiality but adds a login step. The answer is to make protection **usable**, not to remove it.

- One control can serve several goals: a **tested backup** supports availability and can restore integrity.
- Avoid both extremes: "nothing bad has happened, so we are safe" and "everything is a disaster".

Week 1 - Five Words, Safe Response, Ethics

Five words describe a security problem

Term	Meaning	Mina's account
Asset	Something valuable	Her account, email, files, grades
Threat	A possible cause of harm	An attacker
Vulnerability	A weakness that could be used	A reused or phished password
Control	A safeguard that reduces risk	MFA, unique password, backups
Risk	The possibility and consequence of harm	Losing privacy, grades and reputation before a deadline

Case: Mina's university account

One account covers LMS, email, submissions, grades and files. One compromise hits **all three** goals: private email read (C), messages sent as her and assignment replaced (I), lockout before the deadline (A). It also harms **other people**: classmates and the professor receive the fake messages.

People, process, technology

People make choices	Process says what to do	Technology blocks, detects, records, recovers

Technology alone is never enough: a strong password system fails if a person gives the password away.

Pause, check, report

PAUSE: do not click, reply, install, share	CHECK: verify sender, request, address, context	REPORT: use the official channel

Warning signs: unexpected urgency, unfamiliar sender, mismatched address, request for credentials. **Pressure is a signal to slow down.** Verify through a route **you** choose (open the official site yourself), never through the link in the message.

Permission defines ethical practice

Authorized practice has a clear **owner, scope, time, method and purpose**.

Authorized	Unauthorized
Scanning an instructor-provided lab machine during the scheduled exercise, using approved steps, submitting findings privately	Scanning a university server because it is reachable, then sharing what you found

Do not confuse

"Reachable" does not mean "allowed". The scan can be technically identical; **permission, scope and how results are handled** make the difference. When scope is unclear: **stop and ask**.

Defense in depth

Several layers: attentive users, strong authentication, device protection, network controls, monitoring, backups. **Any single control can fail**, so another layer catches what one misses.

Week 2 - Assets

Four asset types

Type	Meaning	Examples	Real case
Information	Useful facts we depend on	Patient records, grades, passwords	Equifax 2017
Devices	Physical tools that support work	Laptops, phones, hospital computers	NHS, May 2017
People	Knowledge, work and wellbeing	Staff, patients, students	NHS, May 2017
Services	Functions people rely on	Online exams, messaging, payments	Facebook, 4 Oct 2021

An asset list is only the beginning

Question	Meaning	Example
Value	Why does it matter?	Two identical computers: one shows a public notice, one supports urgent care. **Same price, different value.**
Dependency	What does it need to work?	Facebook 2021: a network setting change cut communication between data centers. The computers were fine but the services failed.
Protection goals	What must be preserved?	Use C, I and A.

Key idea
Value comes from what the asset **does**, not what it costs. Services that share one dependency **fail together**.

What can an asset lose?

Goal	Real case
Confidentiality	Equifax: private data was exposed
Integrity	GitLab: database data was deleted
Availability	NHS: healthcare work was disrupted

Week 2 - Harm and Protection

Four roles

Term	Meaning	Equifax 2017
Threat	A possible cause of harm	The attackers
Vulnerability	A weakness	The unfixed software flaw
Exploit	A way to use a weakness	Using the flaw to get in
Control	A protective measure	A **verified** patch

Do not confuse
The attackers are the threat. The flaw is the vulnerability. Using the flaw is the exploit. **Vulnerability = the flaw. Exploit = its use.**

Three kinds of threat (M / A / P)

Malicious	Accidental	Physical
Deliberate harm	Unintended harm	Physical damage
WannaCry 2017: ransomware disrupted NHS services	GitLab 2017: database data deleted by mistake	Kakao 2022: data-center fire

A threat does not have to be a person with bad intentions.

Incident vs risk

Incident	Risk
Something **has happened** that harms or threatens security	**Possible future** harm, judged by chance and seriousness

Controls: prevent, detect, recover

PREVENT: fix a known flaw	DETECT: check records of unusual access	RECOVER: restore from a tested copy

- **Patch** = a software update that fixes a problem. Equifax lesson: a patch instruction is not enough; the patch must be **applied and checked** on the real system.
- **Backup** = make a separate copy. **Restore** = use the copy to recover. GitLab lesson: **recovery must be tested**. A backup you never restored from is an assumption.

Account controls

Term	Meaning
Phishing	A deceptive message or website that tries to trick someone
Credentials	Evidence used to prove identity, such as login details
Authentication	The process of checking a claimed identity
MFA	More than one **kind** of identity evidence: something you **know** (password) + something you **have** (security key)

Uber, Sep 2022	Cloudflare, 2022
After repeated requests, a contractor **approved** a login	Staff entered details on a fake site, but **security keys blocked** the login
Control depended on a person's judgment under pressure	**Origin-bound** key checks which website is asking, automatically
Attacker got in	Stolen login details were not enough

Week 2 - Assessing Risk

Risk = possible harm judged by **likelihood** and **impact**.

Before you rate anything

Define	Ask	Example
Event	What harmful event do we mean?	An attacker gains account access
Period	Over what period?	Before next month's exam
Current controls	What protection works now?	Security keys block one route

Separate **facts** (supported by evidence), **assumptions** (accepted for the exercise) and **unknowns** (missing evidence).

The two scales

Score	Likelihood	Impact
1	**Unlikely**: not expected under stated conditions	**Minor**: small disruption, routine recovery
2	**Possible**: a believable route to harm exists	**Serious**: important work or privacy affected, extra help needed
3	**Likely**: expected, or strongly supported by evidence	**Severe**: essential service lost, or harm hard to reverse

Risk matrix: Score = Likelihood × Impact

Likelihood ↓ / Impact →	1 Minor	2 Serious	3 Severe
3 Likely	3 Medium	6 High	9 High
2 Possible	2 Low	4 Medium	6 High
1 Unlikely	1 Low	2 Low	3 Medium

High-yield: the bands

1–2 = Low, 3–4 = Medium, 6–9 = High. The score 5 cannot occur. Always write the working: "L = 2 (possible) × I = 3 (severe) = 6, High".

Worked examples from the slides

Scenario	L	I	Score	Level
WannaCry-like disruption, essential care stops	3	3	9	High
GitLab-like deletion, but a recent restore works	2	1	2	Low
Cloudflare-like route with strong key protection	1	3	3	Medium
Update failure interrupts essential work	2	3	6	High

What each control changes

Control	Reduces	Because
Verified **patch**	**Likelihood**	That exploitation route is closed (other weaknesses may remain)
Tested **restore**	**Impact**	Less is lost after the event (some harm can remain)

The week 2 assignment pattern (exam in 30 days)

A public exam system has an unfixed flaw and an untested backup. Four sentences: *the asset is … it matters because … / the threat could use …, which is the weakness / likelihood is … and impact is … because … / our control is …; it reduces …*. Model answer: L 3 × I 3 = 9 High; **patch and verify** (likelihood) and **test the restore** (impact).

Week 3 - Social Engineering

Definition

Social engineering = deception that influences a person's action. It hacks the **human factor** (attention, emotion, habits, working situation), not the computer code. It can arrive by phone, text, email, social media or in person.

Pretext vs requested action

Pretext	Requested action
The situation the attacker invents	What the attacker wants you to do
"Your scholarship payment failed."	Send a password, approve a login, transfer money

> **Key idea**
> The story may be believable. **The action is what causes harm**, so judge the action.

Why it works

Trust: we cooperate with familiar people	Pressure: fear or a deadline narrows attention	Attention: a busy moment interrupts checking

Six levers (plus secrecy)

Lever	Sounds like
Authority	"I am from the court."
Fear	"Your account is involved in a crime."
Urgency	"You have ten minutes."
Familiarity	"It's me. I changed my number."
Reward	"You won a tuition grant."
Curiosity	"Someone posted your photo."
(Secrecy)	"Keep this private until approval." It removes the friend who would say "that looks odd".

In person

Baiting	Tailgating
An attractive item or offer invites a risky action	Someone follows an authorized person into a restricted area
Unknown USB labelled "Exam answers"	A visitor asks you to hold a secure door
Do not plug it in; hand it to IT	Stay polite: point to reception or call the host

Uber: MFA fatigue

Attacker has the password	Repeated approval prompts, first rejected	One accepted prompt gives access

Nothing about the request changed; the **person's state** changed. A better control than "be more careful": phishing-resistant MFA (origin-bound key), limits and alerts on repeated prompts, and a rule that **a prompt you did not start is reported, never approved**.

Verified contact vs claimed identity

Verified contact	Claimed identity
You reach the person through a route you already trust, and confirm the exact request	The message *says* "university", "bank", "court" or "your friend"
	Names, logos and profile pictures can be copied

Week 3 - Phishing and Impersonation

Phishing = deceptive contact that seeks information or an unsafe action.

Five labels, five different features

Term	Feature it describes	Meaning
Phishing	Deception	The broad category
Spear phishing	**Targeting**	Personalized to a person, role or group
Smishing	**Text** channel	Phishing by SMS or text
Vishing	**Voice** channel	Phishing by call
Impersonation	**Claimed identity**	Pretending to be someone else

High-yield

Each label describes a different feature, so **one attack can carry several labels**.

Contact	Labels
Generic email requests a new sign-in	Broad phishing
SMS uses your project name and a fake tutor identity	Smishing + spear phishing + impersonation
A caller posing as a bank asks for a code	Vishing + impersonation
A copied friend profile requests urgent money	Impersonation

Cases

Case	What happened	Lesson
Korean "daughter" call (reported Jul 2018)	Caller posed as a man's daughter, claimed an accident, asked for 20 million won. The real daughter was at home; no payment.	Fear + urgency + familiarity. Control: call back on a **known number**, or a family code word.
Twilio (Aug 2022)	Texts impersonated internal IT; staff used fake sign-in pages	A familiar name does not prove the destination. One account exposed **other people's** data, so limit what an account can reach.
Changwon District Court warning (8 Jul 2025)	"Court mail was returned": use a link, give information, install an app	Authority + unfamiliar legal language adds pressure. Find the court's number yourself.
Hong Kong deepfake meeting (reported 2024)	Fake CFO email, then a fabricated video meeting; about **HK$200 million** transferred	**Recognition is not authorization.**

Authorization vs recognition

Authorization	Recognition
"This request passed our agreed verification and approval process."	"That looks like my manager."

A **deepfake** uses AI to imitate a person's appearance or voice. Seeing a face raises confidence, but a sensitive request still needs an independent check.

Week 3 - Warning Signs and Reporting

U + P + S

Unexpected: new contact, unusual login	Pressure: deadline, threat, secrecy	Sensitive action: credentials, money, device access

One sign alone may be innocent. All three together is the pattern to stop on. Requests that deserve a pause: a **password or code**, a **payment change**, **device access** (install an app, enable remote access).

Read the full hostname

```
https://login.campus.example/student           real: belongs to campus.example
https://campus.example.verify-now.test/student  fake: belongs to verify-now.test
```

A hostname is read **from the right**. Open the known portal yourself.

Appearance is limited evidence

Stronger checks	Easy to imitate
An expected task and a known contact route	Logo, display name, fluent grammar, familiar layout
Confirming the exact request through the official process	**HTTPS**: it also protects a connection to a deceptive site

A QR code is a hidden link. For an urgent tuition QR notice the strongest action is **open the usual portal**, not "scan now" and not "ask the sender".

Pause, verify, report

PAUSE: stop the action, end the pressure	VERIFY: separate known route, confirm the exact request	REPORT: official channel, explain what happened

A verification route is **independent** when you obtained it **separately** from the suspicious contact.

Reporting routes in South Korea

Situation	Route	Purpose
Money sent, or active voice-phishing fraud	**112** and your **bank's official contact**	Report urgently and request **payment suspension**
Suspicious SMS or possibly malicious app	**118 KISA**	Technical advice about the message or device
Campus account or university message	Known **university IT** office	Report and arrange an account response

If you already acted

What happened	Immediate response
Opened a link only	Close it, report it, mention any downloads or permissions
Entered credentials or approved a login	Reset access and end sessions through a trusted route; contact IT
Installed an app or allowed remote access	Stop using the device for sensitive tasks; get help **from another device**
Sent money	112 and the bank **immediately**; request payment suspension

Respond supportively ("Thank you for telling me"). **Shame makes people hide information and delay help.**

Week 4 - Identity and Accounts

The lecture is built on three security decisions: **how can access be compromised** (identity and accounts), **which control stops which attack** (passwords and MFA), and **why should this request be allowed** (roles and permissions).

Identification, authentication, authorization

Check	Meaning	Campus example
Identification	An account **claim**	"I am mina.student."
Authentication	**Proof** for that account	The accepted proof matches.
Authorization	**Permission** for that action	Mina requests a grade edit.

> **Key idea**
> **An accepted password can belong to the wrong person.** Authentication only shows that the proof matched the account, not that the real owner typed it.

Case: Mina's password was stolen

A stranger signs in as Mina, a student. The slides ask three questions and the lecture answers them section by section. *(The slides do not print the answers; these follow from the three checks above.)*

Question	Answer
Which security check accepted the stranger?	**Authentication.** The stolen password was valid proof for Mina's account.
Should the account be able to change grades?	**No.** That is **authorization**: a student role reads its own record and edits nothing, whoever is signed in.
What evidence would you collect?	The **access log**: sign-in time, the account, each event and the decision (allow or deny), plus active sessions.

An account, a session and a permission

Item	Purpose	Failure example
Account record	Stores role, status and scope	A former TA stays active
Session	Recognizes later requests	A stolen session is reused
Permission check	Decides access to a resource	One student reads another's data

A successful sign-in **does not settle every later request**. Each request still needs its own permission check.

Common routes into an account

Route	What the attacker uses	A relevant defense
Password guessing	Likely password candidates	Attempt limits and strong passwords
Credential stuffing	A pair leaked from **another site**	A unique password per service
Phishing	A deceptive request for proof	Phishing-resistant authentication
Recovery or session abuse	A weak recovery path or a stolen session	Secure recovery and session controls

Do not confuse

Guessing tries likely candidates. **Credential stuffing** does not guess: it reuses a username and password pair that already leaked somewhere else, so it works only when you **reused** the password.

The cost of guessing

PIN length	Possible values
Four digits	**10,000** (includes leading zeroes)
Six digits	**1,000,000**

The time to guess also depends on the **guessing rate** and the **defenses**, not only on the number of possibilities.

Online guessing vs offline guessing

	Online	Offline
Where guesses go	To the **login service**	To a **copied hash** on the attacker's device
What can slow them	Server attempt limits and monitoring	A costly password-hashing scheme
Does login MFA help?	It can block account entry	It does **not** prevent hash testing

Activity: a hash as the target (CyberChef)

A fictional database contains one SHA-256 value. You hash each word of a candidate list (a **dictionary**) in CyberChef (SHA2, size 256, 64 rounds) and compare the **complete** output with the target.

Candidate	SHA-256 starts with	Full target match
123456	`8d969eef6eca…`	No
password	`5e884898da28…`	No
welcome	`280d44ab1e9f…`	No
campus123	`4cb48ed6cefe…`	**Yes**

High-yield

The guess produced a match. The hash was not decrypted. A hash is one-way: the attacker hashes guesses until one equals the target. And a short list that fails **does not prove a password is safe**; it only shows those few words were wrong.

Test your knowledge (slide questions)

(The slides give no answers; these follow from the tables above.)

Question	Answer
Why can login rate limits fail to stop offline guessing?	Offline guesses never reach the login service. They run against a copied hash on the attacker's own device, so the server's limits are never asked.
How does credential stuffing differ from guessing?	Guessing tries likely candidates; stuffing uses a real pair leaked from another site.
A correct password opens someone else's record. Which additional check failed?	**Authorization** (the permission check): authentication passed, but the resource did not belong to that account.

Week 4 - Passwords and Stronger Proof

A strong sign-in needs both **good credentials** and **correct enforcement**.

Long, unique passwords

Property	Meaning
Length	Prefer a long, randomly generated password
Uniqueness	A different password for each service
Predictability	`Campus2026!` follows a recognizable pattern (word + year + symbol), so it is easy to guess

NIST SP 800-63B-4: minimum **15 characters** for password-only sign-in. A password used **within MFA** may have a minimum of **8**.

A password manager makes uniqueness practical

Generate: a different random password for each login	Store: keep them in a protected vault	Protect the vault: strong master secret and available MFA

Password storage that slows guessing

Storage choice	What it changes
Unique random salt per password	Identical passwords do not share a reusable hash
A **password-hashing scheme**, such as **Argon2id**	Each guess consumes configured time and memory
Fast SHA-256 alone, as in the demo	Allows rapid guesses; it illustrates the weakness

> **Do not confuse**
>
> A **salt is stored with the hash and does not have to be secret.** Its job is to make every hash different, not to hide anything. The slowness comes from the hashing scheme (Argon2id), not from the salt.

Password reuse spreads one breach

Fictional service	Password choice	After the forum password leaks
Student forum	Same password as the LMS	Forum access is at risk
LMS	Reused forum password	The leaked pair may work here too
Email	Different generated password	The leaked password does not match

MFA adds another check if a stolen password is tried.

MFA uses different factor types

Factor type	Examples
Something you **know**	Password, PIN, security answer
Something you **have**	Phone, authenticator app, hardware security key
Something you **are**	Fingerprint, face recognition

Sign-in combination	Factor types	MFA?
Password and security question	Know + know	**No**
Password and authenticator-app code	Know + have	Yes
Security key activated with its PIN	Have + know	Yes

Trap

Two screens can still ask for the same kind of proof. MFA means two **different factor types**, not two steps.

MFA methods face different attacks

Method or issue	What to remember
Typed one-time code	A deceptive site may **relay** it
Unexpected approval prompt	**Deny it** and investigate through the official service (this is the Uber MFA-fatigue pattern from weeks 2 and 3)
Passkey or FIDO security key	Cryptographic proof **binds authentication to the service** (why Cloudflare's keys held in week 2)
Faulty server enforcement	The app may accept access **before MFA is complete**

Activity: access before MFA is complete

PortSwigger lab "2FA simple bypass". The lab supplies a valid password, but the second-factor code is unavailable. Prediction asked: will the protected account page open?

Observed stage	Expected in this vulnerable lab
Password stage	Accepted
Verification-code stage	No code supplied
Direct request for the protected page	**Account page opens**

The application failed to require completed MFA. The fix is a check on the protected route itself:

Session state	Protected account page
No authenticated session	Deny or send to sign-in
Password accepted, MFA still pending	Require the second factor
MFA complete and permission valid	Allow this request

Key idea

A verification screen alone does not enforce the rule. Showing an MFA page is not the same as refusing every protected page until MFA is finished.

Recovery and response also protect the account

When	What to do
Before an incident	Protect the recovery email and store backup codes securely
When access looks wrong	Use the **official service** to change exposed credentials and **revoke unfamiliar sessions**
After containment	Review recovery methods, MFA enrollment and activity

Week 4 - Roles and Permissions

Each request needs the right **action**, **resource** and **scope**.

One request, three policy questions

Subject: Mina's signed-in student account	Action: read	Resource: Joon's grade record in section B

The question to ask every time: **does the policy allow this subject to perform this action here?**

Roles grant actions. Scope limits resources.

Role	Read grades	Edit grades
Student	Own record	No
Teaching assistant	Assigned section	Assigned section
Lecturer	Assigned course	Assigned course
Disabled account	No	No

Horizontal and vertical access failures

Failure	Example	Missing boundary
Horizontal	Mina reads Joon's record	Another **user's resource** (same level)
Vertical	A student changes course grades	A **more privileged action** (higher level)

Activity: another user's account data

PortSwigger lab "User ID controlled by request parameter". You sign in with the supplied test account, then change the user ID in the request.

Request	Signed-in account	Requested account
Original	wiener	wiener
Changed user ID	wiener	carlos

Expected vulnerable result: **another account's API key appears**. The session and the resource differ, so the failed check concerns **ownership of the requested resource**. This is a **horizontal** failure.

Least privilege limits the possible damage

Least privilege = each account gets only the access its assignment needs.

Assignment	Access needed	Access to deny
Student checks a result	Read own grade	Edit grades
TA grades section A	Edit assigned section	Edit section B
Lecturer teaches one course	Manage that course's grades	Manage unrelated courses

Access changes when the assignment changes

Join: create a personal account, approve required access	Change: replace old scope when duties or courses change	Leave: remove access and revoke applicable sessions

A **shared login makes individual accountability harder**: the log shows the account, not which person used it.

An access log reveals the failed boundary

Time	Account	Event	Decision
10:01	mina.student	Password sign-in	Success
10:02	mina.student	Read Mina's grade	Allow
10:03	mina.student	Read Joon's grade	**Allow**
10:04	mina.student	Edit Joon's grade	Deny

The slide asks which row conflicts with the policy and what the log can prove. *(The slides give no answer; this follows from the role table.)*

- **Row 10:03 conflicts.** A student may read only their **own** record, so reading Joon's grade should be denied. It is a **horizontal** failure. Row 10:04 is correct: the vertical boundary held.
- **What the log proves:** which **account** did what, when, and what the system decided. It does **not** prove that the **person** was Mina, because the password may have been stolen.

Three ideas to keep

Idea	One sentence
Identity	An account claim needs verified proof.
Authentication	Unique secrets and correctly enforced MFA protect sign-in.
Authorization	Every request needs permission within its allowed scope.

Week 5 - Malware Categories

Malware = software intentionally designed to cause harm: steal information, disrupt service, spy, gain control, or enable later attacks.

> **Key idea**
> Malware is identified by its **purpose and actions**, not by its name, appearance or symptoms. Some malware hides quietly, and **a symptom alone does not prove infection**.

Six categories

Category	Slide example	How it behaves	What helps
Virus	Sality	Activates when an infected file or program is **executed**; copies itself into other content	Do not share or run untrusted files
Worm	Conficker	**Propagates across networks** by exploiting weaknesses; no user needs to open a file	Fast patching, segmentation
Trojan	SocGholish (fake browser update)	**Disguised** as a game, update, document or pirated app	Trusted sources only; a filename proves nothing
Ransomware	WannaCry	**Encrypts or blocks** systems, may also steal data	Backups; **payment does not guarantee recovery**
Spyware	Spyware.KeyLogger	**Collects information**; a keylogger captures keystrokes	Monitoring, endpoint protection (often no visible sign)
Bot	Neutrino Bot	Lets an **external operator** use the device for spam, fraud, attacks	Monitoring for hidden activity

> **Do not confuse**
> A **virus needs a user action** (running or sharing an infected file). A **worm spreads by itself** through reachable, unpatched systems. WannaCry was **ransomware that also spread as a worm**.

Name the type (practise this)

Observation	Most likely type
Infected program shared on USB; other executables become infected	Virus
Several unpatched computers infected without users opening a file	Worm
A "free game" installs an unwanted remote-control program	Trojan
Course files no longer open; a screen demands payment	Ransomware
A program secretly records what a student types	Spyware / keylogger
A device sends attack traffic when a remote operator says so	Bot
A laptop is slow, but no scan, process or network evidence exists	**Unknown, possibly not malware**
A fake update steals information and downloads ransomware	Trojan + spyware + ransomware

Evidence that separates malware from an ordinary fault: running processes, network connections, recent changes, scan results, startup and configuration changes. A computer **can** be infected with no warning window; only ransomware wants to be seen.

Week 5 - Infection Paths

Malware depends on unsafe content, weak configuration, excessive privilege or unpatched software.

Seven paths and their controls

Path	How it works	Control
Malicious messages	Attachments, links, fake login pages	Verify unexpected content; filtering; user reporting
Untrusted downloads	Pirated software, unofficial stores, fake updates	Approved sources; check publisher and update path
Unpatched vulnerabilities	Known flaws exploited when updates are delayed	Prioritize internet-facing and critical systems; replace unsupported software
Excess privilege	Admin access lets malware change more and disable controls	**Standard accounts** for daily work
Removable media	Unknown or infected USB devices	Media policy; do not connect found devices
Weak configuration	Auto-run, exposed services, default credentials, disabled protections	Secure baselines; monitor configuration changes
Supply chain	Legitimate updates or vendors are compromised	Trusted signed sources; track dependencies and supplier notices

An attachment from a **known contact** can still be dangerous: the account may be compromised, the address spoofed, or the contact forwarding it without knowing.

The infection story structure

Initial contact	Execution	Privilege	Persistence	Impact	Recovery

Story	Contact	Execution	Persistence	Control
Email attachment	User receives an infected document	User **opens** it	Startup entry or scheduled task	Filtering, verify content, standard accounts
Fake software / update	User downloads a fake game or update	User **runs** the installer	Installed program, auto-start	Approved sources, restrict installation
Network worm	Vulnerable computer is **reachable**	Worm exploits an unpatched service, **no user action**	Service or system component	Patch quickly, segmentation
Infected USB	User connects the USB	User **runs** the infected file	Copies to other files and media	Media policy, disable auto-run

High-yield

This six-stage path was the week 5 assignment. Be ready to write one story stage by stage, with a control placed against **each stage**, not all at the end.

Week 5 - Protect and Respond at the Endpoint

Four endpoint controls

Control	Detail to remember
Updates	OS, browsers, applications, **firmware**, security tools. Automatic where appropriate; **track devices that cannot update**.
Endpoint protection	Blocks known threats, flags suspicious files and processes. Detection quality changes over time; **alerts need investigation**.
Secure configuration	Disable unnecessary services, restrict installation, lock screens, encrypt storage. **Defaults prioritize convenience.** Configuration should be repeatable and reviewable.
Backups	**Protected, separated and tested.** A **connected backup may also be encrypted** by ransomware.

Least privilege limits what malicious code can change or access.

If you suspect infection

Stop sensitive work	Avoid unnecessary changes	Report quickly

- **Do not keep experimenting** on the device.
- **Follow guidance before disconnecting critical systems**: staff may need to preserve evidence.

Recovery = a trusted state

Clean system	Weakness fixed	Credentials safe	Data restored	Monitored afterwards

Trap

Restoring files alone may restore the weakness. Fix the cause, and document the cause and the improvement.

Why antivirus is not enough

No tool detects every threat. Protection also depends on configuration, updates, privilege, backups and users. This is week 1's **defense in depth**.

Six questions before recommending anything

Symptom	Infection path	Privilege level	Affected data	Safe first action	Recovery evidence

Library computer activity (model answer)

A fake update was installed, the browser opens unknown pages, and a student used email afterwards. **Behavior:** Trojan from the fake update, possible spyware. **Containment:** stop sensitive use, do not experiment, report to university IT. **Affected accounts:** anything used **after** the installation, starting with email; reset from a **different trusted device**. **Prevention:** restrict installation, standard accounts, approved sources, monitored endpoint protection.

Week 6 - Follow the Network Path

A **network** connects devices so they can exchange data.

Laptop	Access point	Switch	Router / firewall	Internet routers	LMS server

The shared printer hangs off the switch. In the labelled diagram: **A = access point, B = switch, C = Internet routers, D = router / firewall**.

LAN, WAN, Internet

Term	Meaning	Example
LAN	Network in a limited local area	Computers and a printer in one lab
WAN	Links networks over larger distances	A university links two distant sites
Internet	Many connected networks worldwide	Campus reaches a cloud LMS

Endpoint = a device at an end of a communication. **Client** starts a request; **server** provides a service.

The devices in between

Device	What it does	Security concern
Switch	Forwards Ethernet **frames inside a LAN**; learns **MAC addresses**	An unused cable socket can be an entry point
Access point	Lets **wireless** devices join a network	Who can connect, and what can they reach?
Router	Forwards **IP packets between networks**; the **default gateway** is the next router	Settings can be changed by an attacker

Key distinction

Switches connect local devices. Routers connect networks. A home "Wi-Fi router" is router + AP + switch in one box.

Local vs remote

Path	Route
Print job	Laptop → AP → switch → printer. **Stays local.**
LMS request	Laptop → AP → switch → router/firewall → Internet routers → server

If the Internet connection fails, the local printer **still works**. Wi-Fi connects you to a network, which is not the same as the Internet.

Where a risk can begin

Location	What could go wrong	Control
Device	Malware uses the device's connections	Updates and endpoint protection
Wi-Fi or cable socket	An unauthorized device joins	Network access control
Router settings	An attacker changes settings	Protected admin access and updates

WannaCry from the network side: it spread to **reachable, unpatched** Windows systems through a vulnerable **SMB** (file sharing) service. Reduce spread by installing the fix and restricting unnecessary SMB traffic.

Week 6 - Read a Network Connection

Four terms, four questions

Question	Term	Classroom example
Where is it?	**IP address**	Laptop 192.168.10.24, gateway 192.168.10.1, LMS 198.51.100.20
Which service?	**Port**	443 = HTTPS, 22 = SSH
Which rules?	**Protocol**	IP, TCP, TLS, HTTP
What address matches the name?	**DNS**	lms.example.com → 198.51.100.20

- An IP address identifies a **network interface**. **It does not prove a person's identity.**
- **NAT** (Network Address Translation) changes address information as traffic passes, so many **private** addresses share one **public** address (203.0.113.5).

Protocols

Protocol	Plain English
IP	Delivers packets between networks
TCP	Delivers data reliably and in order
TLS	Protects a connection's data: encryption and certificate checks
HTTP	Defines web requests and responses

HTTPS = HTTP protected by TLS. A **certificate** is digital evidence used to check the server's identity. **Encryption** makes content unreadable without the right keys.

DNS and the URL

Device asks: lms.example.com?	Resolver answers: 198.51.100.20	Device connects to 198.51.100.20

URL part	Meaning
`https`	Use HTTP protected by TLS
`lms.example.com`	Domain name; DNS finds its address
`/course/6`	Path to a resource
(443)	Default HTTPS port when none is written

The HTTPS protection boundary

Question	What HTTPS tells us
Can a nearby observer read the page content?	**Normally no**, when TLS works correctly
Is every website using HTTPS honest?	**No.** A phishing site can also use HTTPS
Can malware read data on my own device?	**Yes.** Endpoint security still matters
Is all network information hidden?	**No.** IP addresses and traffic timing may remain visible

High-yield

HTTPS protects **content in transit between the TLS endpoints**, and nothing else. In browser DevTools a row is a **resource request, not one packet**, and the browser shows clear content because it **is** one endpoint.

Week 6 - Locate and Reduce Risk

A useful explanation names the **location**, the **weakness** and the **control**.

Five locations

Device: endpoint protection, updates	Access: authenticated Wi-Fi	Boundary: firewall rules	Data in transit: TLS	Server: permissions

Named risks

Risk	Where	What it is	Response
Evil twin	Access	A fake access point imitating a trusted Wi-Fi name. An SSID proves only the advertised name.	Verify the network, follow approved setup, **stop at certificate warnings**
DNS spoofing	DNS	False DNS information redirects traffic	It **does not automatically defeat TLS**: the fake server still needs a valid certificate for that name
On-path attacker	In transit	Someone positioned to intercept or influence traffic	HTTP is exposed; correct HTTPS protects content
Too much exposure	Service	A server reachable in more ways than needed	Firewall: allow 443 to the public, deny public SSH 22, allow an approved admin path
Excessive access	Server	Encrypted request, but the user gets more than they should	Authentication and authorization

Firewall = software or hardware that allows or blocks traffic using rules.

Authentication vs authorization

Authentication	Authorization
Who are you? Checks **identity**	*What may you do?* Checks **permissions**

Segmentation

Divides a network into groups and controls communication between them. Guest devices → staff records server: **deny**. Guest devices → Internet: **allow**. It limits unnecessary paths and an incident's **spread**.

Small office activity (model answer)

Risk	Control	Why it helps
Guests can reach staff systems	Separate guest access, enforce traffic rules	Limits access to private services
Administration is public	Allow only an approved admin path	Reduces unnecessary exposure
Printer firmware is old	Update it, or restrict it until replaced	Reduces exploitable weaknesses

The café certificate warning

A warning does not say **where** the problem is. It could be the **device** (wrong clock, malware, intercepting software), the **network** (fake hotspot), or the **website** (expired or wrong certificate). Name the location first.

Week 7 - Control Connections: Firewalls and Segmentation

What a firewall does

A **firewall** is software or hardware that enforces security rules to **allow or block connections** between networks or hosts.

Direction at your laptop	Inbound vs Outbound	Stateful reply handling

Direction	Meaning	Everyday example
Outbound	Your laptop **starts** a connection to an outside service	Your browser opens the university LMS
Inbound	Another device **starts** a connection to your laptop	A classmate connects to your shared folder

Key principle

A reply to your web request belongs to an existing allowed connection. Modern stateful firewalls track outbound connection state: when you request an LMS page, the server's reply is allowed back in without opening your laptop to unsolicited inbound connections.

Writing a useful firewall rule

A useful firewall rule never says just "allow" or "deny": it explicitly names the traffic using four questions.

Source (who starts it?)	Destination (where does it go?)	Service / Port (which service?)	Decision (allow or deny?)

Source	Destination and service	Decision	Rationale
Guest network	Internet web browsing (HTTP/HTTPS)	**Allow**	Required baseline access for visitors
Guest network	Staff payroll server, any service	**Deny**	Guests have no business need to reach payroll
Employee device	Accessing payroll (port 443)	**Allow**	Authorized business task

Access requires an **explicit reason**. A secure network follows **default deny**: all traffic is blocked unless an explicit rule allows it.

Activity: Block only the test program (Windows Defender Firewall)

This activity demonstrates host-based firewall rule creation and granularity.

1. **Record baseline:** Run `"%SystemRoot%\System32\curl.exe" --head --max-time 10 https://google.com`. Output: `HTTP/1.1 200 OK`. The baseline works.
2. **Create blocking rule in `wf.msc`:**
   - In *Windows Defender Firewall with Advanced Security* (`wf.msc`), go to **Outbound Rules** → **New Rule**.
   - Rule Type: **Program**.
   - Program Path: `%SystemRoot%\System32\curl.exe`.
   - Action: **Block the connection**.
   - Profile: Select all (Domain, Private, Public).
   - Name: `W7_Block_Curl`.
3. **Compare results:**

- Run `curl` again: curl **cannot complete the connection** and times out.
- Open `https://google.com` in your web browser: the page **opens normally**.
- Reason: The rule targeted `%SystemRoot%\System32\curl.exe` specifically, leaving other web clients unaffected.

4. **Undo and verify:** Delete `W7_Block_Curl` from Outbound Rules. Run curl again: `200 OK` returns. A complete experiment proves working → blocked → working again.

Network segmentation

Network segmentation means separating devices or services into distinct groups and controlling the communications between them.

Guest devices	Traffic rules: ALLOW to Internet, DENY to Staff records server

Group	Needs to reach	Must NOT reach	Enforcement
Guest network	Public Internet	Staff servers, payroll, internal printers	Firewall blocks inter-group routing
Staff network	Internet, staff servers	Untrusted guest devices	Dedicated VLAN + authenticated access

Trap
A different Wi-Fi name (SSID) alone is not segmentation. If the guest Wi-Fi and staff Wi-Fi connect to the same underlying local subnet without firewall filtering or VLAN separation, guest devices can still scan and reach staff servers.

Week 7 - Observe and Protect Traffic: IDS, IPS, and Boundaries

IDS and IPS: detection vs prevention

Term	Full name	Operation	Office example
IDS	Intrusion Detection System	Watches for suspicious activity and **raises an alert** (passive / out-of-band)	Repeated unusual port connections trigger a security warning
IPS	Intrusion Prevention System	Inspects inline and **acts on detections to block or drop traffic** (active / inline)	An inline sensor drops traffic matching a known exploit signature

An alert needs context

An alert is **evidence to investigate**, not a final conclusion.

Time	Evidence	Question / Context	Investigation step
10:00	Staff laptop opens payroll using HTTPS	Expected routine work?	Normal business activity
10:01	Guest device tries several staff service ports	Approved vulnerability test or unwanted probing?	Check source IP and authorization
10:02	Sensor raises "unusual connection pattern"	What should you verify first?	Verify source & permission; check guest boundary

Reasonable response to an alert: `Verify source and permission → Check boundary enforcement → Preserve log / packet evidence → Report finding`

Detection accuracy: false positives vs false negatives

Term	Plain meaning	Example from slides	Impact
False positive	An alert raised for **harmless or legitimate activity**	An approved vulnerability scanner triggers an intrusion alarm	Wastes analyst time; causes alarm fatigue
False negative	**Harmful activity produces no alert**	An unfamiliar or zero-day attack avoids existing detection rules	Silent compromise; attacker operates undetected

Wireshark: packet evidence made visible

Wireshark captures raw frames from the network interface and organizes them into three panes:

Packet list (who sent to whom?)	Packet details (protocol breakdown)	Packet bytes (raw hex / ASCII)

Pane	What it displays	How to use it
Top: Packet list	Summary table: packet number, time, source IP, destination IP, protocol, length, info	Scan for connection sequences, strange ports, or burst patterns
Middle: Packet details	Hierarchical tree of protocol headers: Frame → Ethernet → IP → TCP → HTTP/TLS	Expand a layer to inspect specific fields (e.g. Host, URI path, status code)
Bottom: Packet bytes	Raw captured bytes in hexadecimal on the left and ASCII on the right	View exact payload characters corresponding to the selected field

Activity: Read an HTTP request in `http.cap`

- **Filter:** `http.request` displays only HTTP request packets.
- **Selecting request `/download.html`:**
  - Method: `GET` (requests a resource).
  - Host: `www.ethereal.com` (named web server).
  - Path: `/download.html` (requested web resource).
  - Destination: TCP port 80 (standard unencrypted HTTP port).
- **Core security lesson:**
  - In plain HTTP, **all request data is visible in plaintext** to any network observer (on-path attacker, Wi-Fi eavesdropper, rogue router).
  - With correctly configured **HTTPS**, TLS encrypts application content: an observer sees only IP addresses, port 443, and the domain name (via SNI/DNS), but **cannot read the request path, headers, cookies, or payload**.

Encryption protection boundaries: WPA, TLS, and VPN

Encryption is not an all-or-nothing shield; every encryption mechanism has a **specific protection boundary**.

Protection	Protected connection	What remains outside it (NOT protected)
WPA2 / WPA3	Your device to the **wireless access point (AP)**	The rest of the network path (switch, router, ISP, Internet)
HTTPS with TLS	Your browser to the **web server's TLS endpoint**	Data already on a compromised endpoint; traffic volume / timing
Encrypted VPN	Your device to the **VPN gateway**	Traffic **beyond the gateway** (still needs internal auth & HTTPS)

Remote worker's laptop	[Encrypted VPN tunnel]	VPN gateway	[Internal LAN]	Office payroll service

Key distinction

These protections work together (defense in depth). An encrypted VPN gets you securely through the Internet into the office network; inside the office, HTTPS still protects application data, and access controls restrict which records you may view.

Matching protection to the problem

Situation	Suitable control	Important limitation
A guest must not reach payroll	Separate guest network + firewall **deny** rule	A different Wi-Fi SSID alone without network rules is insufficient
An analyst needs to notice unusual traffic	**IDS** alerting and log monitoring	Alerts can be wrong (false positives and false negatives); requires human investigation
A student submits work over café Wi-Fi	Valid **HTTPS** to the verified university URL	HTTPS proves encrypted transit to the server; it does **not** prove the site is honest or the laptop is malware-free

Week 7 - Secure Wi-Fi and Router Hardening

The two different router passwords

Every home and small-office Wi-Fi router uses two distinct passwords for two completely different purposes:

Password	Purpose	Who uses it	Risk if weak or default
Wi-Fi password (Passphrase)	Allows devices to **join the wireless network** and encrypts local wireless traffic	All authorized wireless users	Strangers join the LAN, eavesdrop, or consume bandwidth
Router admin password	Allows an administrator to **change router settings** (firewall, DNS, port forwards, Wi-Fi key)	Network administrator only	Anyone on the network can take full control of the router, redirect DNS, or disable defenses

Important

Always use different, strong passwords for Wi-Fi access and router administration. Leaving the router admin password as default (`admin` / `admin` or `admin` / `password`) allows any guest or attacker who joins the Wi-Fi to compromise the entire network infrastructure.

Choosing a Wi-Fi security mode

Security mode	Plain meaning	Decision / Recommendation
WPA3-Personal	Modern wireless security; uses SAE (Simultaneous Authentication of Equals) to resist offline dictionary attacks; provides forward secrecy	**Prefer whenever all devices support it**
WPA2/WPA3 Transitional	Mixed compatibility mode: newer devices use WPA3, older devices use WPA2	Use as a transition option when supporting older hardware
WPA2-Personal (AES)	Established standard using AES encryption (WPA2-PSK CCMP)	**Use when WPA3 is unavailable**; still secure with a strong passphrase
WEP, WPA/TKIP, Open	Obsolete, cryptographically broken, or completely unencrypted	**Avoid completely** for any private or home network
Enterprise (802.1X / EAP)	Users sign in with individual usernames and credentials verified by a RADIUS server	Standard for university and enterprise networks

Router hardening practices

Hardening reduces unnecessary exposure and fixes known weaknesses:

Setting	Practical choice	Why it helps
Admin access	Set a unique strong password; **disable remote (WAN) admin**	Prevents outside Internet users and unauthorized locals from modifying settings
Firmware updates	Install vendor firmware updates regularly	Patches known software bugs and security vulnerabilities in the router OS
WPS (Wi-Fi Protected Setup)	**Disable WPS** if not actively pairing	WPS PIN authentication has critical design flaws easily brute-forced in hours
Guest network	Enable separate guest SSID with client isolation	Keeps visitor devices isolated from private home or office systems

Activity: Router emulator configuration (TP-Link Archer AX55)

The lab activity practiced configuring wireless settings in the TP-Link web interface emulator:

1. Navigate: **Advanced** → **Wireless** → **Wireless Settings**.
2. **SSID (Network Name):** Set a descriptive name (e.g. `StudyLab_Staff`). (SSID = advertised Wi-Fi name).
3. **Security:** Select **WPA3-Personal** (or **WPA2-PSK [AES]** if older clients exist).
4. **Password:** Set a long, complex passphrase.
5. **Save:** Apply settings and reboot if required.

Every Real Case in One Table

Case	When	What happened	What it teaches	Week
WannaCry / NHS	May 2017	Ransomware disrupted hospital services; spread as a worm through unpatched SMB	Malicious threat, availability, patching, reachability	2, 5, 6
Equifax	2017	Attackers used an unfixed software flaw to reach personal data	Vulnerability vs exploit; a patch must be applied **and verified**; confidentiality	2
GitLab	2017	Database data deleted by mistake; recovery was hard	Accidental threat; integrity; backup is not restore	2
Facebook	4 Oct 2021	Network setting change cut data centers off; services down	Dependency; availability	2
Kakao	2022	Data-center fire disrupted services	Physical threat	2
Uber	Sep 2022	Contractor approved a login after repeated prompts	MFA fatigue; controls that rely on judgment under pressure are weak	2, 3
Cloudflare	2022	Staff typed details into a fake site; security keys blocked the login	Origin-bound, phishing-resistant MFA	2
Korean "daughter" call	Jul 2018	Vishing with family impersonation, 20 million won requested	Emotion blocks the pause; verify by a known number	3
Twilio	Aug 2022	Smishing impersonating internal IT; fake sign-in pages	A familiar name is not the destination; limit an account's reach	3
Changwon District Court	8 Jul 2025	Fake "returned court mail" calls and texts	Authority + unfamiliar legal language	3
Hong Kong deepfake	2024	Fake CFO email and fabricated video meeting, about HK$200M	Recognition is not authorization	3
Sality, Conficker, SocGholish, Spyware.KeyLogger, Neutrino Bot	—	Slide examples of virus, worm, Trojan, spyware, bot	One example per malware category	5
Guest vs payroll server	Slide scenario	Guest tries payroll service ports; blocked by rule; IDS flags probing	Network segmentation, explicit deny rule, IDS context	7
Windows Firewall curl test	Lab activity	Blocked `curl.exe` outbound; curl failed while browser opened Google	Host firewall rules can target specific executables	7
Wireshark http.cap capture	Lab activity	Plain HTTP GET exposed host, path, and headers to packet capture	Plain HTTP lacks confidentiality; HTTPS encrypts payload	7

Case	When	What happened	What it teaches	Week
Router admin compromise	Architecture	Default admin credentials allow Wi-Fi guests to control router	Two-password model; router hardening; disable remote admin & WPS	7

Commonly Confused Concepts

Do not confuse	Correct distinction
Threat vs vulnerability	Threat = what could cause harm (the attackers). Vulnerability = the weakness that lets it work (the flaw).
Vulnerability vs exploit	The flaw vs the **use** of the flaw.
Incident vs risk	Has happened vs possible future harm.
Likelihood vs impact	Chance of the event vs seriousness of the consequences.
Patch vs restore	A patch lowers **likelihood**; a tested restore lowers **impact**.
Backup vs restore	Making a copy vs using it to recover. Only a **tested** restore counts.
Confidentiality vs integrity	Who may **see** it vs whether it is **correct**.
Integrity vs availability	Correct and complete vs usable when needed. A corrupted file can lose both.
Authentication vs authorization	Who are you vs what may you do.
Recognition vs authorization	"Looks like my manager" vs "passed our approval process".
Identification vs authentication	The account **claim** ("I am mina.student") vs the **proof** for that account.
Account vs session	The stored record (role, status, scope) vs what recognizes your later requests after sign-in.
Password guessing vs credential stuffing	Trying likely candidates vs reusing a pair leaked from another site.
Online vs offline guessing	Guesses sent to the login service (rate limits help) vs tested against a copied hash (only costly hashing helps).
Matching a hash vs decrypting it	A guess was hashed and compared; nothing was reversed.
Salt vs password-hashing scheme	Makes identical passwords hash differently (not secret) vs makes each guess slow (Argon2id).
Two steps vs two factors	Password + security question is know + know, so it is **not** MFA.
MFA screen vs MFA enforcement	Showing a code page vs refusing protected pages until MFA is complete.
Role vs scope	Which **actions** are granted vs which **resources** they apply to.
Horizontal vs vertical failure	Another user's resource at the same level vs a more privileged action.
Pretext vs requested action	The invented story vs what they want you to do.
Phishing vs spear phishing	General message to many vs tailored to a person or group.
Smishing vs vishing	Text channel vs voice channel.
Baiting vs tailgating	Tempting item or offer vs following someone through a secure door.
Virus vs worm	Needs a user to run or share it vs spreads by itself across the network.
Trojan vs virus	Trojan is **disguised** as something useful; a virus **infects other files**.
Spyware vs bot	Collects your information vs lets an outside operator use your device.
Symptom vs evidence	A slow laptop vs scan, process, network or configuration findings.
Switch vs router	Frames inside a LAN vs packets between networks.

Do not confuse	Correct distinction
Wi-Fi vs Internet	A local network connection vs the worldwide set of networks.
IP address vs port	Which destination vs which service there.
IP address vs identity	An address identifies an interface; it does not prove who the person is.
HTTP vs HTTPS	No protection in transit vs TLS-protected content.
HTTPS vs "safe site"	Encrypted connection vs honest owner. A phishing site can use HTTPS.
DNS spoofing vs broken TLS	A false address redirects traffic, but the certificate check still stands.
Evil twin vs on-path attacker	A fake access point vs anyone positioned to intercept traffic.
Firewall vs segmentation	Rules that allow or block traffic vs dividing the network into controlled groups.
Authorized vs reachable	Permission with owner, scope, time, method, purpose vs "I could connect to it".
Inbound vs outbound rule	External host initiating connection to you vs your laptop initiating connection outward.
IDS vs IPS	Detects and raises alerts (passive) vs blocks and drops malicious traffic inline (active).
False positive vs false negative	Alert raised for harmless activity vs no alert raised for harmful activity.
Packet list vs details vs bytes	Wireshark summary table vs protocol header tree vs raw hex/ASCII payload.
Wi-Fi password vs router admin password	Password to connect to wireless LAN vs credentials to configure router settings.
WPA3 vs WPA2 vs WEP	Modern SAE (resists offline dictionary attacks) vs AES-PSK vs obsolete, broken encryption.
WPA boundary vs TLS boundary vs VPN boundary	Hop to access point only vs client-to-server end-to-end vs client-to-gateway tunnel.
Guest SSID vs true segmentation	Broadcasting a second Wi-Fi name vs isolating network subnets and blocking traffic with firewall rules.

How to Answer Scenario Questions

1. "Which CIA goal?"

Seen by the wrong person = C	Changed or wrong = I	Cannot be used when needed = A

Name the goal, then justify with the definition in half a sentence. If two apply, say which is **most** affected and why.

2. "Label this incident"

Asset	Threat	Vulnerability	Exploit	Control

Model: *Equifax. Asset: personal information. Threat: attackers. Vulnerability: the unfixed software flaw. Exploit: using it to gain access. Control: a verified patch.*

3. "Rate the risk"

Define event, period, current controls	Likelihood 1–3 with reason	Impact 1–3 with reason	Multiply	Band	Control and what it lowers

4. "Is this message safe?"

Name the pretext	Name the levers	Name the requested action	Give the independent check	Give the reporting route

5. "Which check failed?" / "Should this request be allowed?"

Identification: who is claimed	Authentication: was the proof accepted	Authorization: subject, action, resource, scope	Name the failed check	Control that fits

Model: *Mina reads Joon's grade. Authentication passed. Authorization failed: a student may read only their own record. Horizontal failure. Control: check ownership of the requested resource on every request.* For a password question, first say whether the guessing is **online** or **offline**, because the control is different.

6. "What malware is this?" / "Trace the infection"

Behavior	Category	What evidence would confirm it	Path: contact, execution, privilege, persistence, impact	Control per stage	Trusted-state recovery

7. "Where is the network risk?"

Location	Weakness	Control that fits that location

Model: *Wi-Fi access. Unknown network operator (evil twin). Verify the approved network and stop at certificate warnings.* Pick risks at **different** locations when asked for two.

8. "Which network defense or Wi-Fi control?"

Identify the boundary	Select the control (Firewall / Segmentation / IDS / WPA3 / VPN)	State the limit of that control

Model: *A guest needs Internet access but must not touch the internal payroll database. Control: network segmentation with an explicit firewall deny rule between guest VLAN and payroll. Limit: giving guests a different Wi-Fi password or SSID alone is insufficient without network separation.*

9. "Analyze an alert or packet capture"

Examine evidence (source, destination, protocol, payload)	Verify context (authorized action or probe?)	Check for false alarm	Preserve evidence and respond

Model: *Wireshark capture shows a GET request with readable headers and path. Conclusion: unencrypted HTTP on port 80. An observer on the local network can read the URL and headers. Fix: enforce HTTPS (port 443 with TLS).*

Self-Check Questions

Try to answer without looking back. These are review questions, not copies of the real midterm.

1. Define computer security in one sentence.
2. What do C, I and A stand for, and what question does each ask?
3. Which CIA goal is most affected when a grade is changed without permission?
4. Why can an accidental error still be a security problem?
5. Name the five words that describe a security problem.
6. What five things define authorized security practice?
7. Why do secure systems use several layers of defense?
8. Name the four asset types with one example each.
9. Two computers cost the same. Why might one be more valuable?
10. In Equifax, what was the threat, the vulnerability and the exploit?
11. Give one example each of a malicious, an accidental and a physical threat.
12. What is the difference between an incident and a risk?
13. Name the three things a control can do, with an example each.
14. Compare what happened at Uber and at Cloudflare in 2022.
15. Why are backup and restore different actions?
16. Likelihood 2 and impact 3: what is the score and the level?
17. Does a patch mainly reduce likelihood or impact? What about a tested restore?
18. What three things must you define before rating a risk?
19. Define social engineering.
20. What is the difference between a pretext and a requested action?
21. Name the six levers attackers use.
22. A caller posing as a bank asks for a code. Which labels apply?
23. Why is "recognition is not authorization" the lesson of the Hong Kong case?
24. Which address is fake and why: `login.campus.example` or `campus.example.verify-now.test`?
25. Which Korean reporting route fits: (a) money already sent, (b) a suspicious SMS, (c) a strange campus-account email?
26. What makes a verification route independent?
27. Define identification, authentication and authorization with the Mina example.
28. A stranger signs in with Mina's stolen password. Which check accepted them?
29. How does credential stuffing differ from password guessing, and which defense fits each?
30. Why do login rate limits not stop offline guessing?
31. In the CyberChef activity, `campus123` matched the target. Was the hash decrypted?
32. What does a salt do, and does it have to be secret?
33. What minimum password lengths does NIST SP 800-63B-4 give?
34. Is a password plus a security question MFA? Why?
35. In the 2FA bypass lab, what did the application fail to do?
36. Mina reads Joon's grade; a student changes course grades. Which failure is horizontal and which is vertical?
37. What is least privilege? Give the TA example.
38. In the access log, which row conflicts with the policy, and what can the log not prove?
39. How is a worm different from a virus?
40. What is a Trojan? Give the slide example.
41. A laptop is slow and nothing else is known. What malware is it?
42. Name four of the seven infection paths.
43. Write the six stages of an infection story.

44. Why may a connected backup be useless against ransomware?
45. What five conditions make recovery complete?
46. Why is antivirus not enough?
47. What is the difference between a switch and a router?
48. The Internet is down. Can you still print to the lab printer? Why?
49. What do an IP address, a port, a protocol and DNS each answer?
50. Name two things HTTPS does **not** protect against.
51. What is an evil twin, and what should you do at a certificate warning?
52. Does DNS spoofing defeat TLS? Explain.
53. Authentication vs authorization?
54. How does segmentation reduce harm?
55. What is the difference between an inbound and an outbound firewall rule?
56. Why does a stateful firewall allow replies to your web requests without a separate inbound rule?
57. What four pieces of information define a useful firewall rule?
58. In the Windows Firewall activity, what happened to Google in the browser when `curl.exe` was blocked? Why?
59. Define network segmentation and explain why a separate Wi-Fi SSID alone is not enough.
60. What is the difference between an IDS and an IPS?
61. What are false positives and false negatives in intrusion detection?
62. Name the three main panes in the Wireshark window and what each shows.
63. What parts of an HTTP request were visible in the `http.cap` Wireshark exercise? What changes with HTTPS?
64. Compare the protection boundaries of WPA3, HTTPS and an encrypted VPN.
65. What two passwords exist on every home/small-office router, and how should they be managed?
66. Which Wi-Fi security mode is preferred today, and which modes should be avoided?
67. Name three router hardening practices besides changing the Wi-Fi password.
68. What is WPS, and why should it be disabled?

Self-Check Answers

1. The ideas, practices and controls used to reduce unauthorized access, unwanted change and harmful disruption.
2. Confidentiality: who may see it? Integrity: is it correct, complete, trustworthy? Availability: can authorized people use it when needed?
3. Integrity: the information was changed improperly.
4. It can make data incorrect, expose information or stop a service even with no attacker.
5. Asset, threat, vulnerability, control, risk.
6. A clear owner, scope, time, method and purpose.
7. Any single control can fail; other layers reduce the chance that one mistake causes major harm.
8. Information (grades), devices (laptops), people (staff), services (online exam).
9. Value comes from what the asset does: one may support an urgent service, so interruption costs more.
10. Threat: the attackers. Vulnerability: the unfixed software flaw. Exploit: using that flaw to gain access.
11. Malicious: WannaCry. Accidental: GitLab deletion. Physical: Kakao data-center fire.
12. An incident has happened; a risk is possible future harm judged by likelihood and impact.
13. Prevent (fix a known flaw), detect (check records of unusual access), recover (restore from a tested copy).
14. Uber: a person approved a login after repeated prompts, so the attacker got in. Cloudflare: staff typed details into a fake site, but origin-bound security keys refused to work there.
15. Backup makes a copy; restore uses it to recover. An untested backup may not restore (GitLab).
16. 2 × 3 = 6, High.
17. A patch reduces likelihood. A tested restore reduces impact.
18. The event, the period and the current controls.
19. Deception that influences a person's action.
20. The pretext is the invented situation; the requested action is what the attacker wants you to do, and it is the action that causes harm.
21. Authority, fear, urgency, familiarity, reward, curiosity.
22. Vishing + impersonation.
23. The employee recognized faces in a video meeting, but the request never passed an independent approval process.
24. The second: reading from the right, it belongs to `verify-now.test`.
25. (a) 112 and the bank, request payment suspension. (b) 118 KISA. (c) University IT.
26. You obtained it separately from the suspicious contact.
27. Identification is the account claim ("I am mina.student"). Authentication is the proof for that account. Authorization is permission for the action (a grade edit).
28. Authentication: the stolen password was valid proof. An accepted password can belong to the wrong person.
29. Guessing tries likely candidates (defense: attempt limits and strong passwords). Stuffing reuses a pair leaked from another site (defense: a unique password per service).
30. The guesses go to a copied hash on the attacker's device, never to the login service. Only a costly password-hashing scheme slows them.
31. No. The guess was hashed and its full output equalled the target. Hashes are matched, not decrypted.
32. It makes identical passwords produce different hashes, so one hash is not reusable. It is stored with the hash and does not have to be secret.
33. 15 characters for password-only sign-in; 8 when the password is used within MFA.
34. No. Both are something you know (know + know). MFA needs different factor types.
35. It did not require completed MFA: a direct request for the protected page opened it after the password stage only.

36. Reading Joon's record is horizontal (another user's resource). A student changing grades is vertical (a more privileged action).
37. Give only the access the assignment needs. A TA grading section A may edit the assigned section and is denied section B.
38. Row 10:03, read Joon's grade: Allow. A student may read only their own record. The log proves what the account did, not that the person was Mina.
39. A worm propagates through networks by itself; a virus depends on a user executing or sharing an infected file.
40. Malware disguised as legitimate or useful software. SocGholish, a fake browser update.
41. Unknown. A symptom is not evidence; you need scan, process, network or configuration findings.
42. Any four of: malicious messages, untrusted downloads, unpatched vulnerabilities, excess privilege, removable media, weak configuration, supply chain.
43. Initial contact, execution, privilege, persistence, impact, recovery.
44. Ransomware can encrypt it too. Backups must be protected, separated and tested.
45. Clean system, weakness fixed, credentials safe, data restored, monitored afterwards.
46. No tool detects every threat; protection also needs configuration, updates, least privilege, backups and users.
47. A switch forwards frames inside a LAN; a router forwards packets between networks.
48. Yes. The print path (laptop → AP → switch → printer) never leaves the LAN.
49. IP: where is it. Port: which service. Protocol: which rules. DNS: which address matches the name.
50. Any two of: a dishonest site owner (phishing sites use HTTPS), malware on your own device, visibility of IP addresses and traffic timing.
51. A fake access point imitating a trusted Wi-Fi name. Stop; do not click through the warning.
52. Not by itself. It can redirect traffic, but the fake server must still present a valid certificate for the name.
53. Authentication checks who you are; authorization checks what you may do.
54. It limits unnecessary communication between groups, so an incident cannot spread freely.
55. Inbound: outside host starts a connection to you. Outbound: your laptop starts a connection outward.
56. The firewall is stateful: it recognizes the incoming packets as replies to an established, allowed outbound session.
57. Source, destination, service/port, and decision (allow or deny).
58. Google still opened normally in the browser because the rule specifically targeted the `%SystemRoot%\System32\curl.exe` program binary.
59. Dividing devices/services into groups and controlling communication between them. A separate SSID alone is not enough if both share the same subnet without firewall filtering.
60. IDS watches traffic and raises an alert (passive); IPS sits inline and actively blocks or drops malicious traffic.
61. False positive: harmless activity triggers an alert. False negative: malicious activity passes undetected without an alert.
62. Packet list (overview of packets: source, destination, protocol), packet details (hierarchical protocol header tree), packet bytes (raw hex/ASCII data).
63. Method (`GET`), host (`www.ethereal.com`), path (`/download.html`), port 80. With HTTPS, application payload and headers are encrypted by TLS.
64. WPA3: device to access point only. HTTPS: browser to web server TLS endpoint. VPN: device to VPN gateway.
65. Wi-Fi password (to join network) and router admin password (to change settings). Always use different, strong passwords and never keep default admin credentials.
66. Preferred: WPA3-Personal (or WPA2-Personal AES fallback). Avoid: WEP, WPA/TKIP, and Open networks.
67. Disable remote (WAN) admin access, apply firmware updates regularly, disable WPS, and enable a dedicated guest network.

68. Wi-Fi Protected Setup; it should be disabled because its PIN authentication mechanism is vulnerable to quick brute-force cracking.

Final 15-Minute Revision Checklist

You should be able to...	Check
Define computer security and the three CIA goals, each with a school example.	☐
Classify a scenario as C, I or A and justify it.	☐
Define asset, threat, vulnerability, exploit, control, risk, incident.	☐
Explain pause-check-report, permission (owner, scope, time, method, purpose) and defense in depth.	☐
List the four asset types and explain value and dependency.	☐
Label the Equifax incident.	☐
Give malicious, accidental and physical threat examples.	☐
Explain prevent / detect / recover, patch, backup vs restore.	☐
Compare Uber and Cloudflare; explain MFA and origin-bound keys.	☐
Draw the 3 × 3 risk matrix with the bands 1–2, 3–4, 6–9.	☐
Say which control lowers likelihood and which lowers impact.	☐
Define social engineering, pretext, requested action and the six levers.	☐
Apply the five phishing labels to a contact, with multiple labels.	☐
Tell the Korean call, Twilio, Changwon and Hong Kong cases with one lesson each.	☐
Read a hostname from the right; explain why HTTPS and logos prove little.	☐
Give the Korean reporting routes (112 + bank, 118 KISA, university IT) and the "already acted" responses.	☐
Separate identification, authentication and authorization, and account, session and permission check.	☐
Give the four routes into an account with a defense for each.	☐
Compare online and offline guessing; explain why a hash match is not decryption.	☐
Explain salt, Argon2id, the NIST 15 / 8 character minimums and what a password manager does.	☐
Name the three factor types and decide whether a sign-in combination is MFA.	☐
Explain the 2FA bypass lab: the protected route must check MFA state.	☐
Reproduce the role table; classify a failure as horizontal or vertical; explain least privilege and join / change / leave.	☐
Read an access log: find the row that breaks the policy and say what the log can and cannot prove.	☐
Define the six malware categories with the slide example for each.	☐
Explain virus vs worm and why WannaCry is both ransomware and worm.	☐
List the seven infection paths with a control for each.	☐
Write an infection story: contact → execution → privilege → persistence → impact → recovery.	☐
List the endpoint controls and the five trusted-state conditions.	☐
Trace laptop → AP → switch → router/firewall → Internet → server; label A–D.	☐
Explain LAN/WAN/Internet, switch/AP/router, IP/port/protocol/DNS, NAT.	☐

You should be able to...	Check
Reproduce the HTTPS protection boundary table.	☐
Explain evil twin, DNS spoofing, on-path attacker, firewall, authentication vs authorization, segmentation.	☐
Explain any network risk as location → weakness → control.	☐
Explain inbound vs outbound firewall rules and stateful reply handling.	☐
Construct a 4-part firewall rule: source, destination, service, allow/deny.	☐
Explain the Windows Defender Firewall `curl.exe` program-blocking experiment.	☐
Define network segmentation and explain why a separate Wi-Fi SSID alone is not enough.	☐
Compare IDS vs IPS, and define false positive vs false negative with examples.	☐
Describe the three panes of Wireshark (packet list, details, bytes) and read an HTTP request.	☐
Compare the protection boundaries of WPA3, HTTPS, and encrypted VPN.	☐
Explain the two-password model on routers and why default admin credentials are dangerous.	☐
Compare Wi-Fi modes (WPA3-Personal, WPA2-AES, WEP, Open) and list four router hardening steps.	☐

Best final strategy

Do not memorize isolated definitions only. Pick one case (WannaCry is the best: it appears in weeks 2, 5 and 6) and practise telling it three ways: as a risk, as malware, and as a network path.

End of Midterm Study Guide